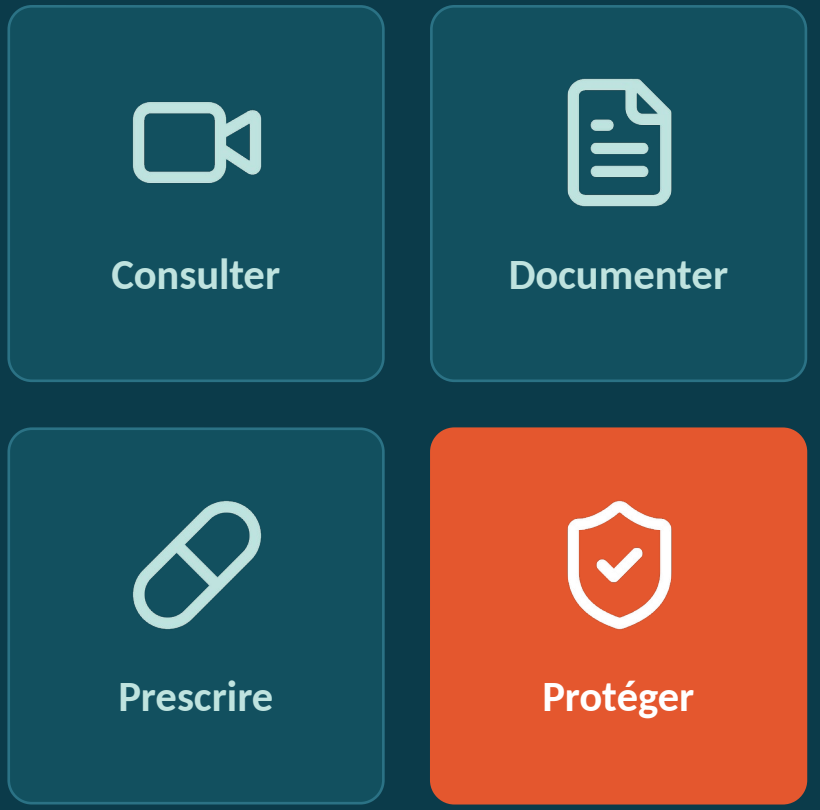
PLATEFORME DE SANTÉ MEDX

Conception de la solution technique

Téléconsultations · Dossier patient · Suivi des ordonnances

Architecture de haut niveau · conception des composants · données et stockage · scalabilité et performances · sécurité et conformité



Mini-projet 5DESI · Proposition d'architecture · 2026

ENJEUX DE CONCEPTION

Ce dont MedX a besoin — et ce qui passe en premier

LA MISSION DE MEDX

Téléconsultations

Réserver, voir un médecin en vidéo, échanger et partager des documents

Dossier patient

Un dossier fiable tenu à vie — disponible en urgence

Suivi des ordonnances

De la signature du médecin au comptoir de la pharmacie

H HAUTE *Fondations non négociables*

- Chiffrement au repos et en transit
- Gestion du dossier patient
- Accès d'urgence
- Authentification et autorisation
- Intégrité et fichiers sécurisés

M MOYENNE *Parcours de soin*

- Planification
- Vidéo · chat · fichiers
- Ordonnances
- Masquage et caviardage
- Agendas externes

B BASSE *Conçues maintenant, livrées en dernier*

- Interface pharmacie
- Préférences
- Suivi des notifications
- Anonymisation
- Paiements
- Remboursements

Les priorités hautes deviennent des principes d'architecture · les moyennes s'appuient dessus · les basses sont conçues maintenant, livrées en dernier

OBJECTIFS ET PRINCIPES DE CONCEPTION

Dimensionnée pour une croissance × 10, guidée par huit principes

10 M	200 k	10 k	99,99 %	< 300 ms
patients inscrits (année 3)	téléconsultations par jour	appels vidéo simultanés en pointe	de disponibilité de l'accès d'urgence	pour servir une synthèse critique

P1

Confidentialité native

Tout chiffrer, minimiser, refuser par défaut

P2

Sécurité du patient d'abord

Le chemin d'urgence tient quand tout lâche

P3

L'intégrité d'abord

L'historique clinique n'est jamais réécrit

P4

Standards plutôt que sur mesure

FHIR · OpenID Connect · WebRTC · OpenAPI

P5

Couplage faible

Événements métier, une base par service

P6

Réutiliser, puis construire

IdP, PSP, SFU réutilisés — logique de soin construite

P7

Monter en largeur, automatiser

Sans état, mise à l'échelle auto, IaC

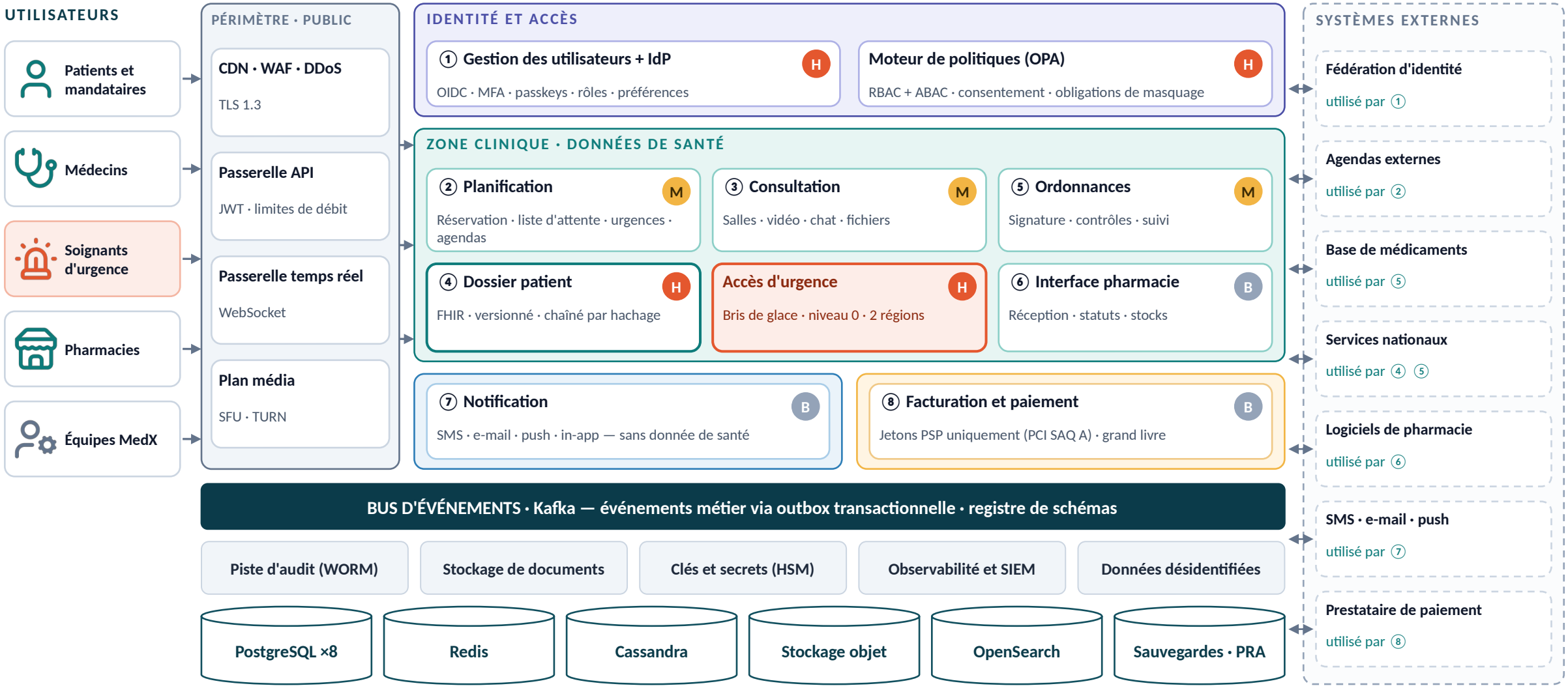
P8

Observable et auditable

Chaque requête tracée, chaque accès audité

ARCHITECTURE DE HAUT NIVEAU

Vue d'ensemble de l'architecture



LOGIQUE DE L'ARCHITECTURE

Un parcours de soin à travers les services

1

Réserver

② Planification · ⑧

Blocage du créneau 10 min + contrainte d'exclusion en base · honoraires pré-autorisés

2

Consulter

③ Consultation

Salle d'attente · SFU WebRTC · chiffrement de bout en bout · chat et fichiers

3

Documenter

④ Dossier patient

Note FHIR signée · versionnée · chaînée par hachage · auditée

4

Prescrire

⑤ Ordonnances

Contrôles allergies et interactions · signature dans un HSM · QR code vérifiable

5

Délivrer et payer

⑥ Pharmacie · ⑧ · ⑦

Statuts de la pharmacie · paiement encaissé · facture · patient notifié

Événements Kafka : RendezVousReserve → ConsultationTerminee → DossierMisAJour → OrdonnanceEmise → StatutDelivranceMisAJour · PaiementEncaisse

Synchrone seulement si un utilisateur attend

Au plus 2 sauts, délais et disjoncteurs partout

Des identifiants, jamais de données cliniques

Les consommateurs lisent le détail sous leur propre autorisation

Outbox transactionnelle

Ni événement perdu ni fantôme · consommateurs idempotents

PRIORITÉ HAUTE · H4

Identité forte, autorisation fine

KEYCLOAK — 3 REALMS, 3 PROFILS DE RISQUE

Patients

Passkey ou mot de passe · MFA selon le risque · biométrie sur mobile · jetons de 10 min liés par DPoP

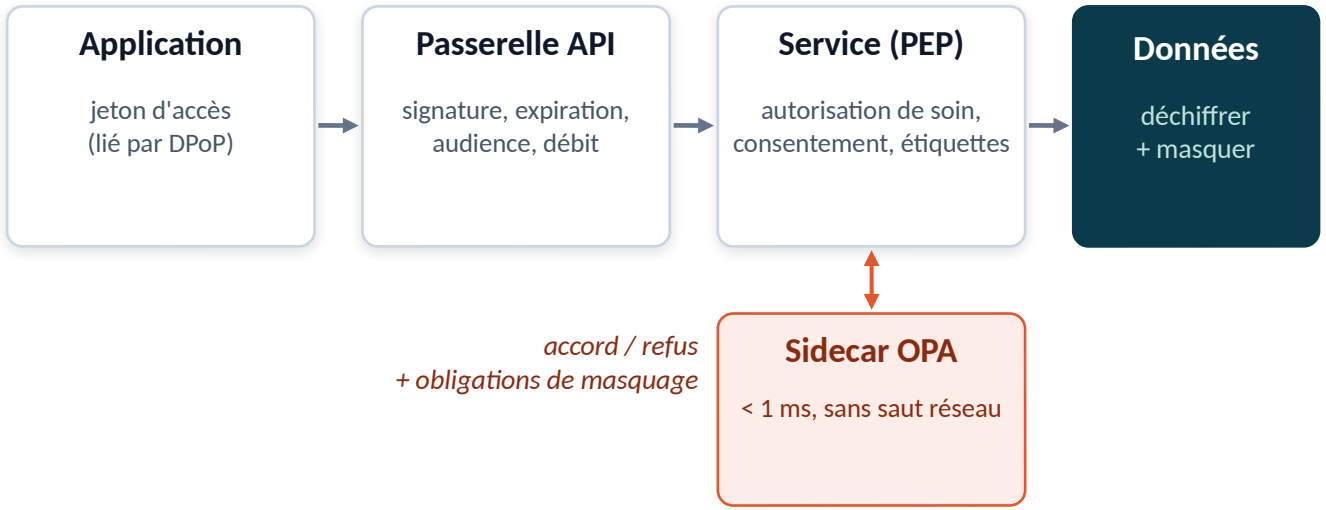
Professionnels

MFA résistante à l'hameçonnage (passkey, carte e-CPS) · ré-authentification avant signature ou bris de glace · inactivité 15 min

Collaborateurs MedX

SSO d'entreprise + clés matérielles · administration juste-à-temps, enregistrée · aucun accès aux données de santé

CHAQUE REQUÊTE SUR DES DONNÉES DE SANTÉ



Décision RBAC + ABAC

Rôle médecin + Relation autorisation de soin + Finalité soins + Consentement étiquettes + Assurance niveau MFA

Politiques sous forme de code : Git → tests unitaires → paquets signés → sidecars. Refus par défaut.

PRIORITÉ HAUTE · H2 · H5

Dossier patient : complet, exact, altération détectable

CHAQUE REQUÊTE TRAVERSE LA MÊME CHAÎNE

1. **Autorisation (PEP → OPA)**
2. **Validation (profils FHIR)**
3. **Provenance (qui, pourquoi)**
4. **Chiffrement (clé patient)**
5. **Chaîne de hachage**
6. **Audit (même transaction)**
7. **Masquage (obligations)**

FHIR R4 + International Patient Summary

Modèle standard avec validation, versionnage et recherche — prêt pour les services nationaux et les hôpitaux.

L'historique n'est jamais réécrit

Versions en ajout seul · notes signées, puis addenda · « saisie erronée » au lieu de suppression.

Altération détectable

Chaîne de hachage par patient · racine de Merkle quotidienne signée dans le HSM, horodatée, stockée en WORM.

La bonne personne, le bon motif

Patient · mandataire · autorisation de soin (30 j) · partage · bris de glace. Pharmaciens et personnel : aucun accès.

MASQUAGE ET CAVIARDAGE (M4)

Agent de support : +33 6 •• •• •• 42 · Pharmacien : aucun diagnostic · Bris de glace : notes de psychothérapie exclues · Patient : résultats publiés après revue · Journaux : jamais de donnée de santé

PRIORITÉ HAUTE · H3

L'accès d'urgence en quelques secondes — justifié a posteriori

1 Identifier

Correspondance exacte : INS, ou nom + date de naissance + sexe

→

2 Déclarer

Code motif + justification en texte libre

→

3 MFA renforcée

Passkey ou carte · droit et opposition vérifiés

→

4 Accès limité

4 heures · lecture seule · ce patient uniquement

→

5 Synthèse < 1 s

Allergies, problèmes, traitements, groupe sanguin, directives

≈ 30 s pour le soignant · p95 < 300 ms par appel d'API · disponibilité 99,99 % · actif dans deux régions

Garde-fous — justifié a posteriori

- Événement d'audit écrit dans la même transaction que l'accès
- Alerte en temps réel au DPO (SIEM)
- Patient informé sous 24 h : qui, quand, quoi
- Revue obligatoire sous 72 h ; abus → suspension
- Opposition possible du patient lorsque la loi le permet

Niveau 0 — résiste aux pannes

- Déploiement séparé à capacité réservée (cloisonnement)
- Synthèse pré-calculée lue sur des répliques locales
- Active dans la région de secours, avec sa propre base d'accès
- Contrôles des jetons et politiques en local (clés, OPA)
- Audit mis en tampon dans l'outbox si la chaîne est en panne

PRIORITÉ HAUTE · H1 · H5

Chiffré partout, une intégrité démontrable

En transit

Applications ↔ périmètre

TLS 1.3 · HSTS · épinglage · hybride post-quantique

Service ↔ service

mTLS dans le maillage, mode STRICT

Service ↔ données

TLS verify-full, identifiants éphémères

Vidéo et audio

DTLS-SRTP + bout en bout (SFrame)

Partenaires

mTLS + OAuth 2.0 · webhooks signés

Au repos — chiffrement d'enveloppe

Clés racines dans le HSM

FIPS 140-3 niveau 3 · jamais exportées

↓

KEK par service · env. · classe

dans le KMS · renouvelée chaque année · usage journalisé

↓

Clé de données par patient / fichier / chat

AES-256-GCM · ≤ 5 min en mémoire

↓

Chiffré + chiffrement du stockage

deux couches indépendantes

Crypto-effacement : détruire les clés d'un patient en fin de conservation → toute copie devient illisible

Intégrité

- Transactions ACID, contraintes, concurrence optimiste
- Historique en ajout seul + chaînes de hachage par patient
- Ancrages quotidiens signés en stockage WORM
- SHA-256 sur chaque fichier · dépôts analysés
- Sauvegardes immuables inter-comptes · restauration testée chaque semaine

PRIORITÉ MOYENNE · M1 – M5

Des parcours de soin construits sur le socle sécurisé

Planification et agendas

M1 · M5

- Blocage 10 min + contrainte d'exclusion → aucune double réservation
- Liste d'attente et file urgente pour les médecins de garde ; signes d'alerte → 15 / 112
- Médecins notifiés en direct (WebSocket + push)
- Google · Microsoft · CalDAV : libre / occupé uniquement

MÉCANISME CLÉ

Une contrainte d'exclusion PostgreSQL sur (médecin, plage horaire) rend physiquement impossible tout chevauchement.

Consultation

M2

- Salle d'attente, jetons de salle éphémères
- SFU WebRTC auto-hébergé dans l'UE + TURN sur 443
- Simulcast, repli audio, reconnexion auto
- Bout en bout en tête-à-tête · aucun enregistrement
- Chat avec accusés · fichiers analysés et chiffrés

MÉCANISME CLÉ

Le plan de contrôle (salles, jetons) est séparé du plan média (SFU) : le média ne touche jamais les services métier.

Ordonnances et masquage

M3 · M4

- Contrôles allergies et interactions à la signature
- Signature dans un HSM · QR code vérifiable en pharmacie
- Modifier = nouvelle version signée ; révoquer = alerte critique
- Le pharmacien ne voit que ce qu'exige la délivrance

MÉCANISME CLÉ

Deux machines à états — statut légal (prescripteur) et délivrance (pharmacie) : jamais « prête » si elle est révoquée.

PRIORITÉ BASSE · B1 – B6

Services de l'écosystème — conçus maintenant, livrés en dernier

Interface pharmacie

B1

- Portail pour chaque pharmacie + API partenaire avec webhooks signés
- Statuts : reçue → prête → délivrée
- Adaptateurs de stocks, disponibilité à proximité

En attendant : ordonnance imprimable avec QR code vérifiable, utilisable dans n'importe quelle pharmacie

Notifications

B2 · B3

- SMS · e-mail · push · in-app, avec files de priorité
- Préférences, heures de silence, plafonds de fréquence
- Suivi de distribution et de lecture — messages sans santé

Une version transactionnelle minimale (confirmations, rappels) arrive avec les fonctionnalités moyennes

Facturation et remboursements

B5 · B6

- Champs hébergés par le PSP → PCI DSS SAQ A
- Pré-autorisation à la réservation, encaissement après
- Grand livre, factures, avoirs, remboursements à double validation

Acheté, pas construit : le prestataire porte les données de carte et la lutte contre la fraude

Anonymisation

B4

- Patients synthétiques pour dév, préprod, démo
- Chaîne d'anonymisation avec k-anonymat
- Validation du DPO · clés de production inutilisables ailleurs

Règle dès le premier jour : les données de santé de production ne quittent jamais la production

PostgreSQL par défaut, stockages spécialisés seulement si justifié

Composant	Système de référence	Utilise aussi	Pourquoi
① **Utilisateurs**	PostgreSQL	Redis (sessions)	Identités ; e-mail chiffré + index aveugle
② **Planification**	PostgreSQL	Redis · OpenSearch	Contrainte d'exclusion : pas de double réservation
③ **Consultation**	PostgreSQL	Cassandra (chat, 30 j)	Chat en ajout intensif avec expiration
④ **Dossier patient**	PostgreSQL (FHIR JSONB)	Répliques ×3 + PRA	ACID, versions, chaîne de hachage · ≈ 10 To
⑤ **Ordonnances**	PostgreSQL	OpenSearch (médicaments)	Versions signées et immuables
⑥ **Pharmacie**	PostgreSQL + PostGIS	Redis (disponibilités)	Recherche géographique, statuts
⑦ **Notification**	Cassandra	PostgreSQL · Redis	Journal très sollicité, TTL 13 mois
⑧ **Facturation**	PostgreSQL	Stockage objet (PDF)	Grand livre en partie double, ajout seul
Documents	Stockage objet	PostgreSQL (métadonnées)	≈ 150 To · versions · Object Lock
Piste d'audit	Stockage objet (WORM)	OpenSearch · SIEM	Archive à altération détectable

PRINCIPES

- Une base par service ; références par identifiant uniquement
- Classer d'abord : C0 public → C4 données de santé sensibles
- Données cliniques, légales et financières en ajout seul
- Caches et index reconstructibles, jamais l'unique copie
- Dossier conservé 20 ans, puis crypto-effacé
- Tout est chiffré, privé, sauvegardé, supervisé

SCALABILITÉ ET PERFORMANCES

Conçue pour une croissance × 10, testée à 2× la pointe

5 k → 10 k	10 k	24 Gbit/s	150 To
req/s d'API en pointe → capacité conçue	appels vidéo simultanés ≈ 100 nœuds SFU	de trafic média sortant en pointe (année 3)	de documents en stockage objet

Mise à l'échelle sur le vrai goulet
Débit, connexions, retard de file, participants

Pré-calculer les chemins critiques
Disponibilités, synthèses d'urgence

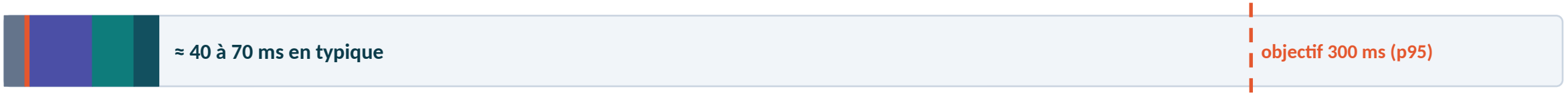
Absorber les pics avec Kafka
Files de priorité pour les notifications

Répliques → partitions → shards
Dossier partitionné par patient si déclenché

Vidéo adaptative
Simulcast, audio d'abord, vidange au retrait

Cellules régionales
Copies isolées par pays / population

BUDGET DE LATENCE DU CHEMIN D'URGENCE (côté serveur)

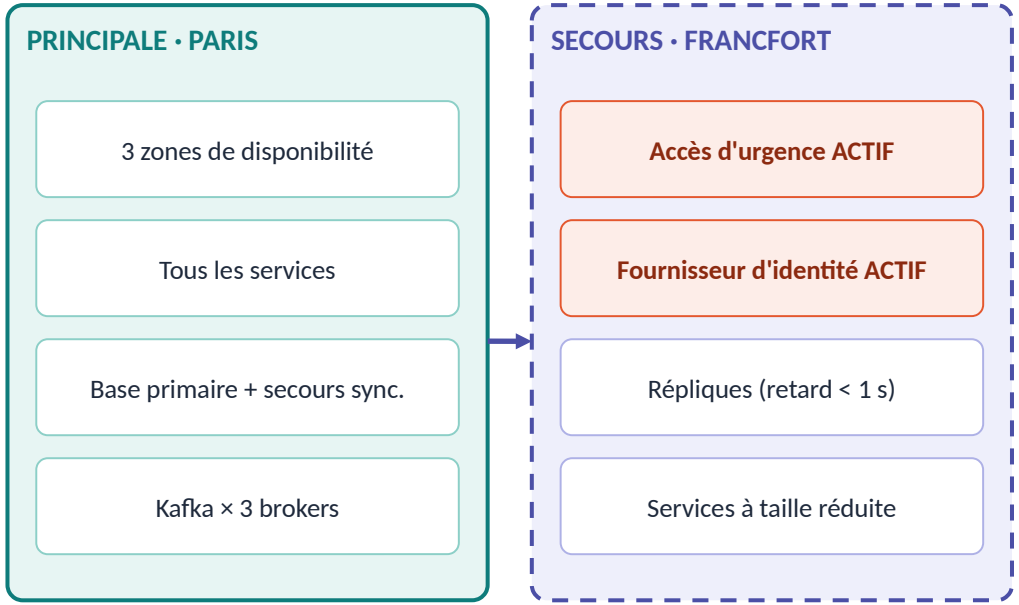


Passerelle 5 ms · politique < 1 ms · accès + audit 15 ms · lecture de la synthèse 10 ms · clé + déchiffrement 6 ms — large marge pour la gigue réseau et les bascules

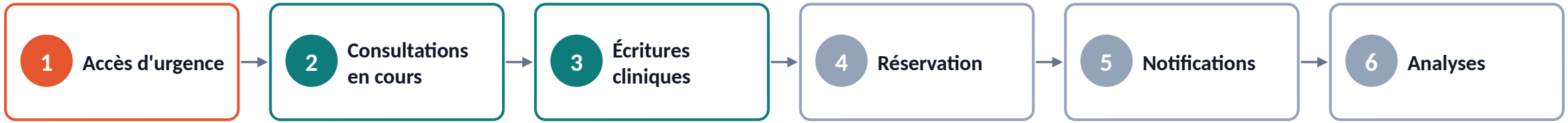
Tests de charge, d'endurance, de chaos et WebRTC à 2× la pointe prévue avant chaque version majeure · SLO avec budgets d'erreur

Résilience par niveau — l'urgence survit à la perte d'une région

Niveau	Périmètre	Disponibilité	RPO	RTO (perte de région)
Niveau 0	Accès d'urgence, connexion, lecture du dossier	**99,99 %**	0 en région · ≤ 1 min	≤ 15 min · actif dans les deux régions
Niveau 1	Écritures au dossier, consultation, planification, ordonnances	**99,95 %**	0 en région · ≤ 1 min	≤ 1 h
Niveau 2	Pharmacie, notification, facturation, analyses	**99,9 %**	≤ 5 min	≤ 4 h



ORDRE DE DÉLESTAGE SOUS CHARGE EXTRÊME (protégé en premier → délesté en premier)



SÉCURITÉ ET CONFORMITÉ

La conformité dès la conception, pas à l'audit

RGPD

Données de santé (art. 9) · AIPD · DPO · notification sous 72 h

HDS

Hébergement certifié · données dans l'EEE

Télémédecine

Patient identifié, consentement, compte rendu au dossier

NIS2

Mesures de risque · signalement 24 h / 72 h

eIDAS

Signature des ordonnances · horodatages qualifiés

PCI DSS

SAQ A : données de carte uniquement chez le PSP

EEDS (EHDS)

Accès et échange par le patient · journal des accès

Prête pour HIPAA

Cellule américaine séparée, mêmes contrôles, BAA

Protection des données dès la conception

- Aucune donnée de santé dans les SMS, e-mails, push, agendas, événements ou journaux
- Les données de production ne quittent jamais la production — données synthétiques ailleurs
- Conservation 20 ans, puis crypto-effacement
- Les patients voient qui a consulté leur dossier
- Modèle de menaces STRIDE : 15 menaces majeures traitées
- Test d'intrusion avant le lancement puis chaque année ; ISO 27001 en années 1-2

Ce que nous avons choisi — et ce à quoi nous avons renoncé

Nous avons choisi	Plutôt que	Parce que	Coût accepté
Microservices en zones de sécurité	Monolithe modulaire	H1 · H3	Complexité d'exploitation
Bris de glace + revue a posteriori	Approbation préalable	H3	Abus possible — détecté et sanctionné
Chiffrement d'enveloppe par patient	Chiffrement des disques seul	H1	Gestion des clés, ≈ 1 ms par requête
Historique en ajout seul + hachage	Mises à jour en place	H2 · H5	≈ 30 % de stockage en plus
SFU auto-hébergé + bout en bout	CPaaS vidéo	H1 · M2	Exploitation média, pas d'enregistrement
Actif-actif pour le niveau 0 seulement	Actif-actif complet	H3	Niveaux 1-2 rétablis en 1 à 4 h
Champs de paiement hébergés (PSP)	Manipuler les cartes	B5	Moins de maîtrise de l'interface

Fiches de décision complètes (14 ADR) avec contexte, alternatives et conséquences : docs/06-decisions-architecture.md

FEUILLE DE ROUTE

Livrée dans l'ordre des priorités de MedX

Phase 0

Fondations

≈ 2 mois

- Zone d'atterrissage, Kubernetes, maillage
- KMS/HSM, Vault, audit, Kafka
- CI/CD avec images signées

Sortie : tout construit depuis le code, 100 % des stockages chiffrés

Phase 1

Socle clinique sécurisé

HAUTE · ≈ 4 mois

- Identité, politiques OPA
- Dossier, intégrité, chiffrement
- Accès d'urgence + région de secours

Sortie : tests d'autorisation verts, bris de glace < 300 ms, exercice PRA

Jalon : AIPD · test d'intrusion · PRA

Phase 2

Parcours de soin

MOYENNE · ≈ 4 mois

- Planification + agendas
- Vidéo, chat, fichiers
- Ordonnances + masquage

Sortie : test de charge à 2× la pointe, qualité vidéo atteinte

Pilote avec des cliniques partenaires

Phase 3

Écosystème

BASSE · ≈ 4 mois

- Interface pharmacie
- Notifications, préférences
- Facturation, remboursements, anonymisation

Sortie : attestation PCI SAQ A, grand livre rapproché

Lancement public

Phase 4

Croissance

en continu

- Services nationaux de e-santé
- Sharding, cellules régionales
- ISO 27001, cellule US

Déclenchée par la croissance mesurée et les nouveaux marchés

EN RÉSUMÉ

Une plateforme zéro confiance, pilotée par les événements, où les données de santé sont chiffrées deux fois, l'historique ne peut pas être réécrit et l'accès d'urgence fonctionne en quelques secondes.



La sécurité comme fondation

TLS 1.3 / mTLS partout · clés par patient dans des HSM · RBAC + ABAC · audit immuable



Accès d'urgence en secondes

Bris de glace sur un chemin de niveau 0 isolé, actif dans deux régions, revu sous 72 h



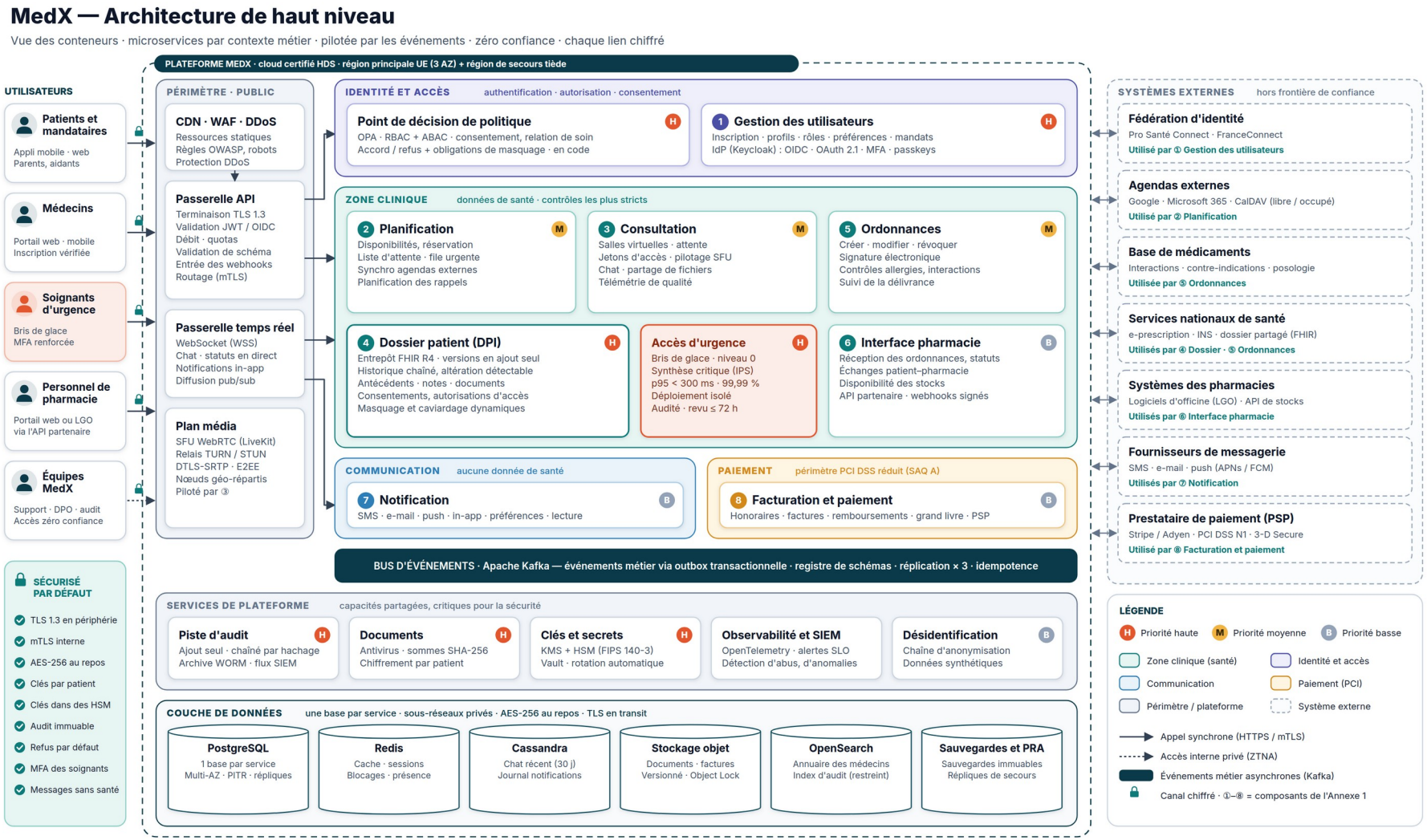
Scalable par conception

Événements, mise à l'échelle auto, répliques → shards → cellules · testée à 2× la pointe

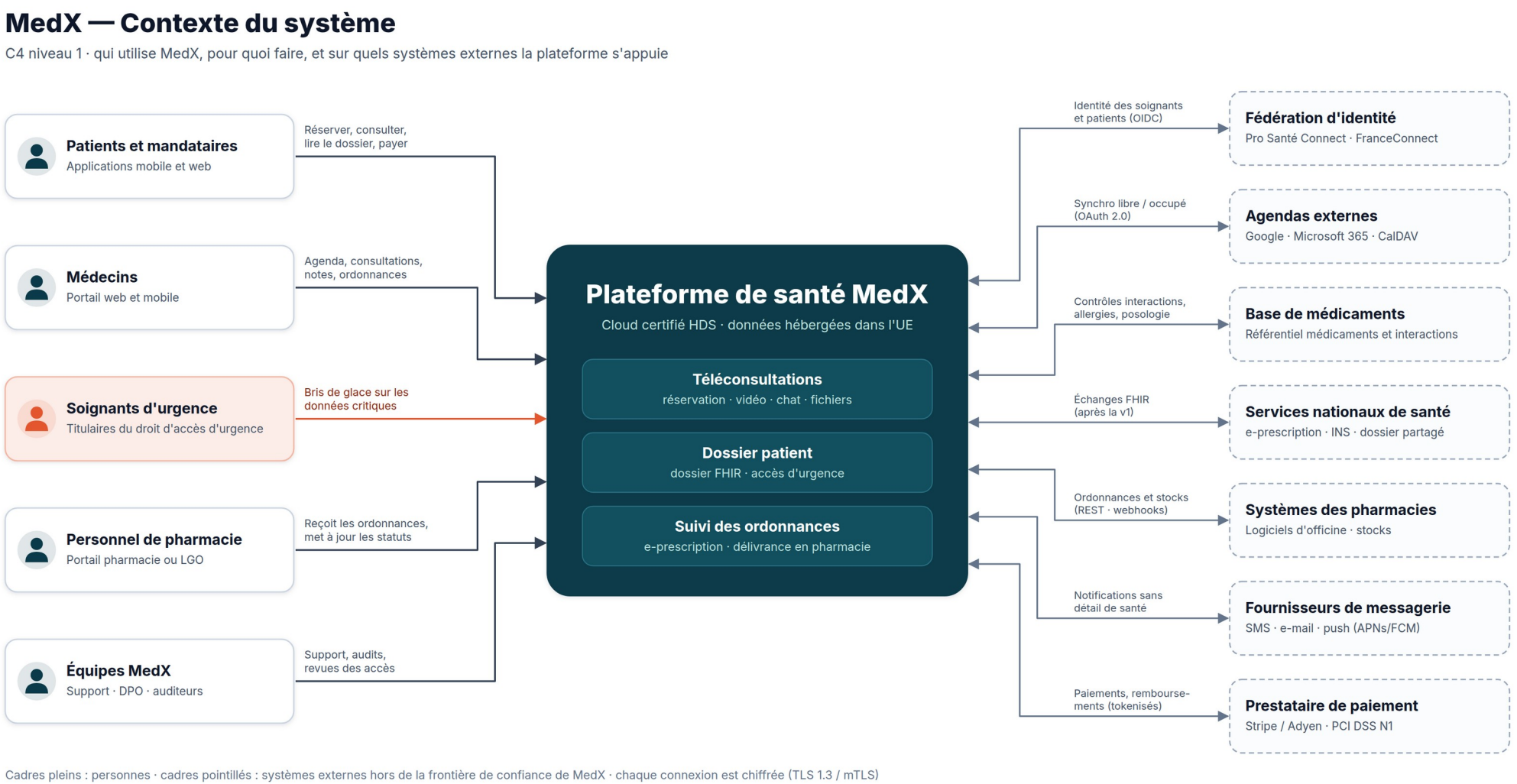
Questions ?

Dossier de conception complet : docs/ · diagrammes/ · presentation/ · rapport/

Architecture de haut niveau détaillée

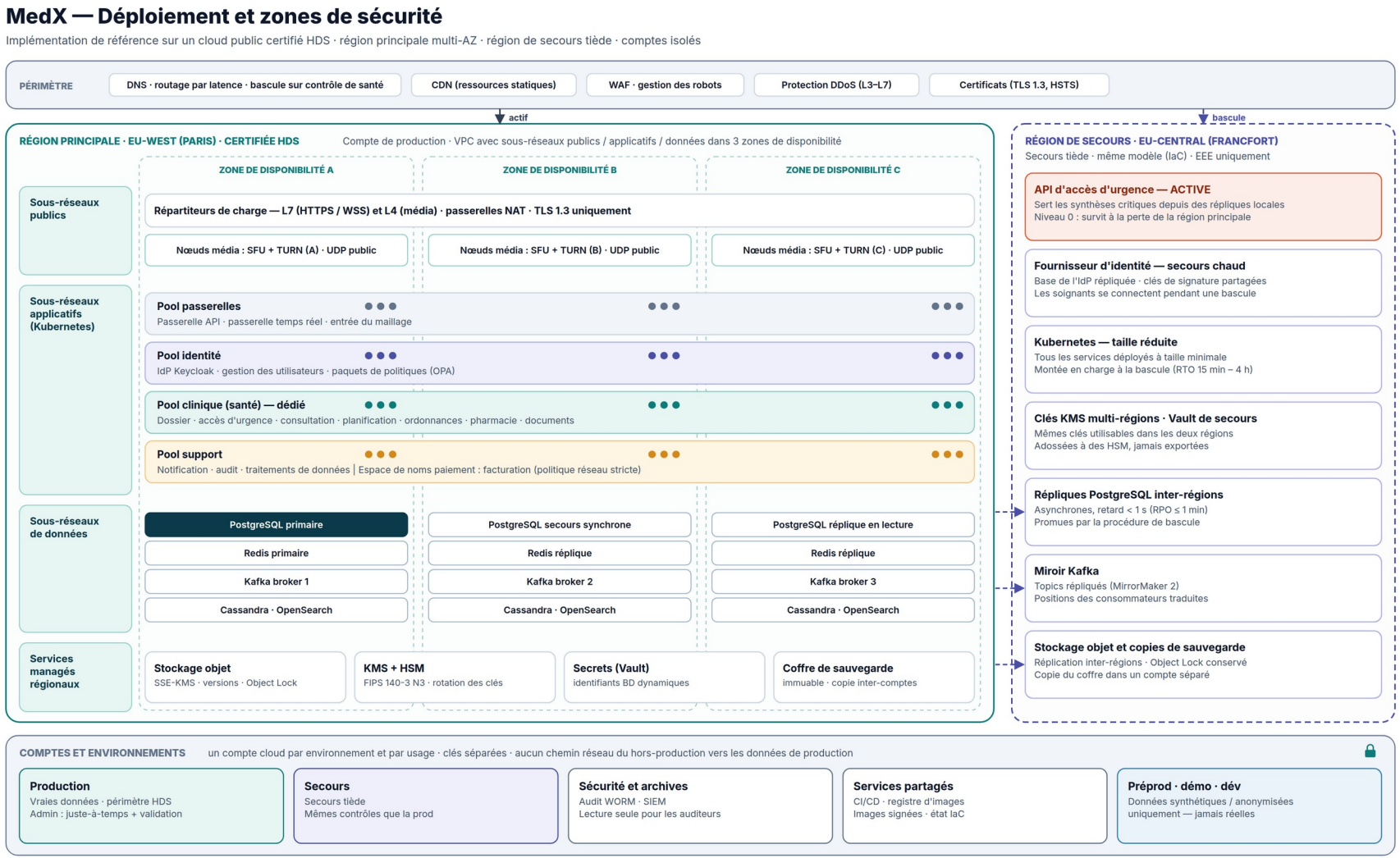


Contexte du système (C4 niveau 1)



Cadres pleins : personnes · cadres pointillés : systèmes externes hors de la frontière de confiance de MedX · chaque connexion est chiffrée (TLS 1.3 / mTLS)

Déploiement et zones de sécurité



Accès d'urgence — flux détaillé

Accès d'urgence (bris de glace)

Exigence de priorité haute H3 · accès immédiat aux données critiques pour les professionnels habilités, avec une traçabilité complète a posteriori

1 Identifier le patient

Recherche exacte uniquement :
INS / identifiant MedX, ou
nom + date de naissance + sexe
Identité minimale pour
confirmer le patient
Ni navigation, ni jokers

→

2 Déclarer l'urgence

Code motif (inconscient,
pronostic vital engagé,
consentement impossible...)
Justification en texte libre
Engagement de responsabilité
« Je serai audité »

→

3 MFA renforcée

Passkey ou carte (e-CPS)
dans les 15 dernières minutes
Le moteur de politiques
vérifie le droit
acces_urgence et
l'opposition du patient

→

4 Autorisation limitée

4 heures · lecture seule
Ce patient uniquement
Autorisation + audit écrits
dans la même transaction
Renouvelable avec un
nouveau motif

→

5 Synthèse en < 1 s

Résumé patient (IPS) :
allergies, problèmes actifs,
traitements, groupe sanguin,
implants, directives
anticipées, contacts
Dossier complet : même accès

Soignant : ≈ 30 secondes de la recherche aux données (étapes humaines) · Système : p95 < 300 ms par appel d'API · Disponibilité 99,99 %

GARDE-FOUS — RESPONSABILITÉ A POSTERIORI (l'accès n'est jamais bloqué, il est toujours justifié)

Audit immuable
AuditEvent, finalité =
traitement d'urgence, conservé
dans la piste WORM

Alerte en temps réel
Le DPO est alerté via le
SIEM dès le début
de l'accès

Patient informé
Avis in-app + e-mail sous
24 h : qui, quand,
ce qui a été consulté

Revue obligatoire
DPO + responsable médical
revoient chaque cas
sous 72 h

Détection des abus
L'analyse comportementale
repère les anomalies ;
sanctions et suspension

RÉSILIENCE — POURQUOI LE CHEMIN DE NIVEAU 0 FONCTIONNE QUAND D'AUTRES SERVICES SONT DÉGRADÉS

- **Déploiement isolé** — cloisonné, capacité réservée
- **Synthèse pré-calculée** — projection, sans jointure
- **Répliques multi-AZ** — + région de secours active
- **Jetons validés en local** — clés de l'IdP en cache
- **Décisions locales** — sidecar OPA, paquets en cache
- **Audit via l'outbox** — sans dépendre de la chaîne d'audit

Qui peut briser la glace ?
Praticiens vérifiés titulaires du droit acces_urgence (médecine d'urgence, gardes, SAMU), accordé par le responsable médical de MedX et revu chaque trimestre. Les patients peuvent s'y opposer lorsque la loi le permet.

Chiffrement en transit et au repos

Chiffrement en transit et au repos

Exigence de priorité haute H1 · chaque saut chiffré · deux couches indépendantes au repos · clés générées et conservées dans un KMS adossé à des HSM

EN TRANSIT — aucun saut en clair, dans la plateforme comme à l'extérieur

Appli patient / médecin	TLS 1.3	Périmètre (WAF · passerelle)

HSTS · suites AEAD modernes uniquement · épinglage de certificats dans les applis mobiles

Périmètre	mTLS	Microservices

Maillage de services · identités SPIFFE · certificats renouvelés toutes les 24 h

Microservices	TLS (verify-full)	Bases · Kafka · Redis

Identifiants de base de données dynamiques et de courte durée émis par Vault

Patient ⇄ médecin	DTLS-SRTP + E2EE	Nœud média SFU

SRTP obligatoire en WebRTC · couche SFrame de bout en bout quand les deux clients la prennent en charge

Systèmes des pharmacies	mTLS + OAuth 2.0	API partenaire

Jetons liés au certificat client · webhooks sortants signés (HMAC-SHA256)

Microservices	TLS 1.2+	Fournisseurs externes

Validation des certificats · aucune donnée de santé transmise (SMS, e-mail, agendas)

Région principale	TLS + KMS	Région de secours

Flux de réplication chiffrés en transit et rechiffrés au repos

AU REPOS — CHIFFREMENT D'ENVELOPPE

HSM — FIPS 140-3 niveau 3

Clés racines dans le HSM
générées dans le matériel · n'en sortent jamais · contrôle par quorum

KEK (KMS, non exportable)	DEK (AES-256-GCM)	DONNÉES (chiffrées uniquement)
KEK dossier — par service · env. · classe	DEK par patient — données cliniques	Champs FHIR sensibles — notes · identifiant national
KEK documents — renouvelée chaque année	DEK par fichier — documents	Documents médicaux — stockage objet
KEK consultation — chaque usage journalisé	DEK par consultation — messages du chat	Historique du chat — stockage récent + archive

chiffre

Seconde couche, indépendante
Disques, bases, stockage objet, Kafka, Redis et sauvegardes sont aussi chiffrés (AES-256, clés KMS).

Crypto-effacement
En fin de conservation, détruire la DEK d'un patient rend toute copie illisible — répliques et sauvegardes comprises.

Rayon d'impact et performances
Une DEK compromise expose un patient, pas la base. Les DEK déchiffrées restent en mémoire ≤ 5 min pour limiter les appels KMS.